

UNIVERSIDAD AUTÓNOMA DE CHIAPAS

Facultad de Ciencias en Física y Matemáticas · IDTS

MedIA — Expediente Clínico Electrónico

Distrito de Salud I · Tuxtla Gutiérrez, Chiapas

DOCUMENTO 3

Módulos del Sistema y API REST

8° Semestre · IDTS · UNACH · Cómputo Distribuido · Enero–Junio 2026

Módulos y API REST — Referencia Técnica

Este documento describe cada módulo del sistema MedIA, sus endpoints REST, los schemas de request/response, las tablas de base de datos que afecta y las reglas de negocio que aplica. La base URL en desarrollo es `http://localhost:8000`. Todos los endpoints excepto `/auth/login` y `/auth/refresh` requieren el header `Authorization: Bearer {access_token}`.

Convención de códigos HTTP usados: 200 OK · 201 Created · 204 No Content · 400 Bad Request · 401 Unauthorized · 403 Forbidden · 404 Not Found · 422 Unprocessable Entity

Módulo 1 — Autenticación (auth)

Gestiona el ciclo completo de identidad: login con 2FA, refresh de tokens JWT, revocación de sesiones y gestión del segundo factor TOTP. Implementa las reglas de seguridad del Req 1, 4 y 8 de Cómputo Forense.

Tablas afectadas

usuarios_sistema, sesiones_invalidas, auditoria_accesos

Reglas aplicadas

- Req 1 Forense: CADA evento de login (exitoso o fallido) se registra en auditoria_accesos con IP (INET), usuario, resultado.
- Req 4 Forense: timestamps en TIMESTAMPTZ UTC, generados por el servidor PostgreSQL.
- Req 8 Forense: contraseñas con Argon2id. totp_secret cifrado con Fernet. Sin hardcoding.
- Bloqueo automático: trigger tr_bloqueo_por_intentos activa bloqueo_hasta tras 5 intentos fallidos.

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/auth/login	No	Login paso 1: verifica username+password. Si 2FA habilitado, devuelve requires_2fa: true y un totp_challenge_token temporal.
POST	/auth/2fa/verify	totp_challenge	Login paso 2: valida código TOTP de 6 dígitos. Si correcto, devuelve access_token y refresh_token.
POST	/auth/refresh	refresh_token	Rota el access_token usando el refresh_token activo. Invalida el refresh anterior (rotación de tokens).
POST	/auth/logout	JWT	Invalida el access_token y el refresh_token insertándolos en sesiones_invalidas. Audita con motivo CIERRE_MANUAL.
GET	/auth/2fa/setup	JWT	Genera un nuevo totp_secret cifrado y retorna la URL de QR para registrar en Authenticator.
POST	/auth/2fa/verify-setup	JWT	Confirma que el usuario puede generar el código correctamente y activa totp_habilitado=true.
GET	/auth/me	JWT	Devuelve los datos del usuario autenticado: id, nombre, rol, establecimiento activo, cédula.

Request: POST /auth/login

Campo	Tipo	Descripción
username	string (max 50)	Nombre de usuario del sistema (ej: dr.morales)
password	string	Contraseña en texto plano. El backend aplica Argon2id verify.

Response: POST /auth/login (sin 2FA activo)

Campo	Tipo	Descripción
access_token	string (JWT)	Token de acceso válido por 15 minutos. Se almacena en memoria.

token_type	string	Siempre 'bearer'.
requires_2fa	boolean	false cuando 2FA no está habilitado para el usuario.

Response: POST /auth/2fa/verify

Campo	Tipo	Descripción
access_token	string (JWT)	JWT con claims: sub (id_usuario), rol, id_establecimiento, exp.
refresh_token	string (JWT)	Token de larga duración (7 días). Solo se usa para rotar el access_token.
token_type	string	Siempre 'bearer'.

Módulo 2 — Personas

Gestión de la entidad base de identidad. Una persona puede ser paciente, usuario del sistema, o representante legal. El módulo incluye los catálogos geográficos INEGI (estados, municipios, localidades) y de lenguas indígenas.

Tablas afectadas

personas, cat_estados, cat_municipios, cat_localidades, cat_lenguas_indigenas

Consideraciones normativas

- CURP es NULL permitido: poblaciones indígenas de Chiapas pueden carecer de ella al momento de la consulta (decisión de diseño para inclusión).
- Domicilio estructurado con FK a cat_localidades (catálogo INEGI), no texto libre. El campo referencia_geografica captura direcciones rurales no formales.
- id_lengua_materna activa alerta visual de barrera lingüística en el módulo de encuentros.

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/personas	JWT (ADMIN, MED)	Registra una nueva persona. Valida que CURP sea único si se proporciona.
GET	/personas	JWT (ADMIN, MED)	Lista personas con paginación. Filtros: nombre, primer_apellido, curp.
GET	/personas/{id}	JWT	Detalle completo de una persona.
PATCH	/personas/{id}	JWT (ADMIN, MED)	Actualiza datos demográficos. El cambio se registra en historial_cambios.
GET	/catalogos/estados	JWT	Catálogo de estados (32). Servido desde CDN en producción.
GET	/catalogos/municipios?estado={clave}	JWT	Municipios del estado. Para Chiapas (07): 124 municipios.
GET	/catalogos/localidades?municipio={clave}	JWT	Localidades del municipio filtrando por tipo (URBANA/RURAL).
GET	/catalogos/lenguas	JWT	Lista de lenguas indígenas del catálogo INALI.

Módulo 3 — Pacientes

Materializa la relación asistencial de una persona con el sistema de salud. El número de expediente es el identificador médico-legal requerido por NOM-004. Una persona puede convertirse en paciente en cualquier establecimiento del Distrito.

Tablas afectadas

pacientes, pacientes_tutores_representantes, personas

Reglas de negocio aplicadas

- Regla 1: los datos básicos de la persona (demografía) son visibles para cualquier médico con encuentro activo, sin restricción de establecimiento.
- NOM-004: el número_expediente se genera automáticamente con formato EXP-YYYY-{secuencia} al crear el paciente.

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/pacientes	JWT (ADMIN, MED)	Crea un nuevo paciente a partir de una persona ya registrada. Genera numero_expediente automáticamente.
GET	/pacientes	JWT (MED, ENFERM)	Lista pacientes con búsqueda por nombre, apellido, número de expediente. Paginado.
GET	/pacientes/{id}	JWT (MED, ENFERM)	Ficha completa del paciente con datos de persona y expediente.
GET	/pacientes/{id}/expediente	JWT (MED)	Expediente completo: antecedentes, alergias, inmunizaciones, encuentros previos. Aplica Reglas 1, 2 y 3.
POST	/pacientes/{id}/tutores	JWT (ADMIN, MED)	Registra representante legal. Requiere documento_legal subido previamente a Azure Blob.
GET	/pacientes/{id}/tutores	JWT (ADMIN, MED)	Lista representantes activos del paciente.
DELETE	/pacientes/{id}/tutores/{id_repr}	JWT (ADMIN)	Borrado lógico del representante. Requiere motivo_baja. Trigger tr_soft_delete registra en auditoria.

Módulo 4 — Expediente (Antecedentes, Alergias, Inmunizaciones)

Gestión del historial clínico permanente del paciente. Todos los subMódulos implementan soft delete forense (Req 6 Cómputo Forense). Los DELETE físicos están prohibidos por permisos de BD.

Tablas afectadas

antecedentes_heredofamiliares, antecedentes_patologicos, antecedentes_no_patologicos, antecedentes_ginecoobstetricos, alergias, inmunizaciones, historial_cambios

Reglas de negocio y seguridad

- Req 6 Forense: NINGUNA tabla del expediente permite DELETE físico. Solo borrado lógico con eliminado_en, eliminado_por y motivo_baja obligatorio.
- Regla 1: alergias y antecedentes visibles para cualquier médico con encuentro activo, independientemente del establecimiento.
- Alerta de alergia: severidad CRÍTICA genera badge rojo prominente en el header de la consulta.
- Antecedentes ginecoobstétricos: el backend valida que sexo del paciente sea 'F' antes de permitir creación.

Endpoints — Alergias

Método	Ruta	Auth requerida	Descripción
GET	/pacientes/{id}/alergias	JWT (MED, ENFERM)	Lista alergias activas del paciente ordenadas por severidad (CRITICA primero).
POST	/pacientes/{id}/alergias	JWT (MED)	Registra nueva alergia. Audita creación en historial_cambios.
PATCH	/pacientes/{id}/alergias/{id_alergia}	JWT (MED)	Actualiza severidad u observaciones. Trigger registra cambio en historial_cambios.
DELETE	/pacientes/{id}/alergias/{id_alergia}	JWT (MED)	Borrado lógico. Requiere motivo_baja. Trigger tr_soft_delete registra en auditoria_accesos con nivel ALTO.

Endpoints — Antecedentes

Método	Ruta	Auth requerida	Descripción
GET	/pacientes/{id}/antecedentes	JWT (MED)	Devuelve los 4 tipos de antecedentes del paciente en un objeto estructurado.
POST	/pacientes/{id}/antecedentes/heredofamiliares	JWT (MED)	Registra antecedente hereditario. Validado y auditado.
POST	/pacientes/{id}/antecedentes/patologicos	JWT (MED)	Registra antecedente patológico personal.
POST	/pacientes/{id}/antecedentes/no-patologicos	JWT (MED)	Registra determinante social de la salud.
POST	/pacientes/{id}/antecedentes/ginecoobstetricos	JWT (MED)	Solo pacientes con sexo='F'. Registra datos reproductivos.
DELETE	/pacientes/{id}/antecedentes/{tipo}/{id_ant}	JWT (MED)	Borrado lógico con motivo_baja obligatorio.

Endpoints — Inmunizaciones

Método	Ruta	Auth requerida	Descripción
GET	/pacientes/{id}/inmunizaciones	JWT (MED, ENFERM)	Lista historial vacunal del paciente.
POST	/pacientes/{id}/inmunizaciones	JWT (MED, ENFERM)	Registra vacuna aplicada conforme al Esquema Nacional.
DELETE	/pacientes/{id}/inmunizaciones/{id_vac}	JWT (MED)	Borrado lógico con motivo_baja.

Módulo 5 — Encuentros Clínicos

Un encuentro clínico es la unidad central del acto médico. Agrupa todas las interacciones de una consulta: notas SOAP, signos vitales, diagnósticos, prescripciones y solicitudes de estudio.

Tablas afectadas

encuentros_clinicos, notas_medicas, notas_soap_detalle, auditoria_accesos

Reglas de negocio

- NOM-004: la fecha_inicio se registra con TIMESTAMPTZ del servidor (UTC). No editable por el cliente.
- El cierre de un encuentro (PATCH /cerrar) es irreversible y activa la generación del PDF resumen.
- Regla 4: apertura y cierre registrados en auditoria_accesos con nivel_severidad MEDIO.

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/encuentros	JWT (MED)	Abre un encuentro clínico para un paciente. Registra el médico, establecimiento y motivo de consulta.
GET	/encuentros	JWT (MED, ENFERM)	Lista encuentros activos del establecimiento actual del médico autenticado.
GET	/encuentros/{id}	JWT (MED, ENFERM)	Detalle del encuentro con todos los subcomponentes (notas, signos, diagnósticos).
PATCH	/encuentros/{id}/cerrar	JWT (MED)	Cierra el encuentro. Requiere que al menos una nota SOAP esté firmada.
GET	/pacientes/{id}/encuentros	JWT (MED)	Historial de encuentros del paciente. Aplica Regla 2 y 3 para acceso cross-establecimiento.

Request: POST /encuentros

Campo	Tipo	Descripción
id_paciente	UUID	ID del paciente que será atendido.
motivo_consulta	string (text)	Motivo de consulta en palabras del paciente. Requerido por NOM-004.
tipo_consulta	enum	PRIMERA_VEZ SUBSECUENTE. Determina si se requiere historia clínica completa.

Módulo 6 — Notas Médicas y SOAP

Implementa la metodología SOAP (Subjetivo, Objetivo, Análisis, Plan) requerida por NOM-004-SSA3-2012. Una nota firmada es inmutable: el trigger `tr_notes_protection` en PostgreSQL bloquea cualquier modificación posterior.

Tablas afectadas

`notas_medicas`, `notas_soap_detalle`, `notas_enmienda`, `historial_cambios`, `auditoria_accesos`

Reglas de negocio y normativa

- NOM-004 § 5.10: inmutabilidad del acto médico firmado. Una vez `esta_firmada=TRUE`, el trigger bloquea UPDATE a nivel de BD.
- NOM-151: la firma electrónica simple se implementa mediante el flag `esta_firmada` + timestamp del servidor. El PDF generado incluye cédula, nombre del médico y hash SHA-256 del contenido.
- Correcciones post-firma: SOLO mediante `notas_enmienda` (Addendum). El error original permanece visible con el texto de corrección adjunto.
- Gaps de `NOTAS_PENDIENTES.md` implementados: (1) número de expediente en TopBar desde apertura del encuentro, (2) timestamp guardado automáticamente al avanzar cada paso del stepper, (3) sello visual de inmutabilidad post-firma.

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/encuentros/{id}/notas	JWT (MED)	Crea nota SOAP en borrador. Devuelve <code>id_nota</code> para edición incremental.
PATCH	/notas/{id}	JWT (MED)	Actualiza el contenido de la nota (solo mientras <code>esta_firmada=false</code>).
PATCH	/notas/{id}/firmar	JWT (MED)	Firma electrónica. Activa inmutabilidad. Registra acción SIGN en <code>auditoria_accesos</code> con nivel MEDIO.
POST	/notas/{id}/enmienda	JWT (MED)	Crea un Addendum a una nota firmada. Requiere <code>narrativa_correccion</code> .
GET	/notas/{id}	JWT (MED, ENFERM)	Detalle de la nota con SOAP, enmiendas, diagnósticos y estado de firma.
GET	/notas/{id}/pdf	JWT (MED)	Genera y descarga el PDF de la nota firmada con sello de inmutabilidad NOM-151.
GET	/encuentros/{id}/notas	JWT (MED, ENFERM)	Lista notas del encuentro. Enfermería ve notas pero no puede modificarlas.

Request: POST /encuentros/{id}/notas

Campo	Tipo	Descripción
subjetivo	string (text)	S: Interrogatorio, síntomas referidos por el paciente.
objetivo	string (text)	O: Exploración física, hallazgos objetivos, signos.
analisis	string (text)	A: Razonamiento clínico, diagnósticos presuntivos y diferenciales.
plan	string (text)	P: Plan diagnóstico, terapéutico e indicaciones médicas.
tipo_nota	enum	EVOLUCION INGRESO COMPLEMENTARIA INTERCONSULTA

Response: GET /notas/{id}/pdf (headers HTTP)

Campo	Tipo	Descripción
Content-Type	application/pdf	El PDF se envía directamente en el body.
Content-Disposition	attachment; filename=...	Nombre del archivo: nota_{id_nota}_{fecha}.pdf
X-Document-Hash	string (SHA-256)	Hash SHA-256 del contenido del PDF. Para verificación de integridad (NOM-151).

Módulo 7 — Signos Vitales

Registro de constantes físicas del paciente al inicio del encuentro. Generalmente capturado por Enfermería. Los signos vitales alimentan la vista SQL `v_signos_encuentro` disponible para el módulo de notas.

Tablas afectadas

`signos_vitales`, `encuentros_clinicos`, `historial_cambios`

Reglas de acceso

- Rol ENFERMERIA: puede crear y actualizar signos vitales. No puede acceder a notas SOAP.
- La vista `v_signos_encuentro` expone `signos_vitales JOIN encuentros_clinicos` para que Enfermería consulte sin acceder a datos clínicos del SOAP.

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/encuentros/{id}/signos	JWT (MED, ENFERM)	Registra signos vitales del encuentro. Solo uno por encuentro (actualizable hasta cierre).
GET	/encuentros/{id}/signos	JWT (MED, ENFERM)	Obtiene los signos vitales del encuentro.
PATCH	/encuentros/{id}/signos	JWT (MED, ENFERM)	Actualiza signos vitales (solo mientras el encuentro esté abierto). Trigger registra en <code>historial_cambios</code> .

Request/Response: POST /encuentros/{id}/signos

Campo	Tipo	Descripción
peso_kg	decimal (5,2)	Peso en kilogramos. Requerido.
talla_cm	decimal (5,2)	Estatura en centímetros. Requerida.
temperatura_c	decimal (4,1)	Temperatura corporal en °C. Opcional.
frecuencia_cardiaca	integer	Frecuencia cardíaca en lpm. Opcional.
frecuencia_respiratoria	integer	Frecuencia respiratoria en rpm. Opcional.
presion_sistolica	integer	Presión sistólica en mmHg. Opcional.
presion_diastolica	integer	Presión diastólica en mmHg. Opcional.
saturacion_oxigeno	decimal (4,1)	SpO2 en %. Opcional.

Módulo 8 — Diagnósticos (CIE-10)

Vincula códigos diagnósticos estandarizados CIE-10 con el encuentro clínico. Garantiza interoperabilidad semántica requerida por NOM-024-SSA3-2012. El autocompletado es el mecanismo de captura principal.

Tablas afectadas

diagnosticos_encuentro, cat_cie10, historial_cambios

Notas técnicas (NOTAS_PENDIENTES.md)

- El campo de diagnóstico NO es texto libre en producción. Se conecta al catálogo CIE-10 oficial con búsqueda por código o descripción.
- Al seleccionar un código CIE-10 del dropdown, se guarda tanto codigo_cie como descripcion en diagnosticos_encuentro.

Endpoints

Método	Ruta	Auth requerida	Descripción
GET	/catalogos/cie10	JWT	Búsqueda de diagnósticos. Parámetros: q (texto libre ILIKE en codigo_cie y descripcion), limit (máx 20). Servido desde CDN en prod.
POST	/encuentros/{id}/diagnosticos	JWT (MED)	Asocia un diagnóstico CIE-10 al encuentro. Requiere id_cie10 y tipo (PRESUNTIVO/DEFINITIVO).
GET	/encuentros/{id}/diagnosticos	JWT (MED, ENFERM)	Lista diagnósticos del encuentro con código y descripción CIE-10.
PATCH	/encuentros/{id}/diagnosticos/{id_diag}	JWT (MED)	Cambia tipo de PRESUNTIVO a DEFINITIVO. Trigger registra en historial_cambios.

Módulo 9 — Prescripciones

Generación de receta médica electrónica nominativa vinculada al Cuadro Básico de Medicamentos de la SSA. La alerta de alergia crítica es un control de seguridad del paciente de alta prioridad implementado en el service antes de permitir la prescripción.

Tablas afectadas

prescripciones, cat_medamentos, alergias, historial_cambios

Reglas de negocio críticas

- ALERTA DE ALERGIA: al prescribir, el service verifica activamente en alergias del paciente si la sustancia del medicamento tiene coincidencia (ILIKE). Si severidad=CRÍTICA, devuelve HTTP 409 con mensaje de alerta y requiere confirmación explícita del médico.
- Vinculación al Cuadro Básico: solo se pueden prescribir medicamentos existentes en cat_medamentos. El código codigo_medamento_ssa actúa como puente con el sistema de farmacia externo.
- La receta PDF incluye: cédula del médico, nombre del paciente, numero_expediente, CLUES del establecimiento y timestamp del servidor.

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/encuentros/{id}/prescripciones	JWT (MED)	Prescribe un medicamento. Verifica alergias antes de insertar. Si alergia crítica: HTTP 409.
GET	/encuentros/{id}/prescripciones	JWT (MED, ENFERM)	Lista prescripciones del encuentro.
GET	/encuentros/{id}/prescripciones/pdf	JWT (MED)	Genera la receta médica PDF con todos los medicamentos del encuentro.
GET	/catalogos/medicamentos	JWT	Búsqueda en Cuadro Básico. Parámetros: q (nombre genérico ILIKE), limit (máx 20).

Request: POST /encuentros/{id}/prescripciones

Campo	Tipo	Descripción
id_medicamento	UUID	FK a cat_medamentos. Obligatorio.
dosis	string (50)	Cantidad y unidad. Ej: '500mg'.
via_administracion	string (50)	ORAL INTRAVENOSA TOPICA SUBCUTANEA etc.
frecuencia	string (100)	Descripción de frecuencia. Ej: 'Cada 8 horas por 7 días'.
duracion_dias	integer	Duración del tratamiento en días. Opcional.
indicaciones	string (text)	Instrucciones adicionales para el paciente. Opcional.
confirmar_alergia	boolean	true si el médico confirma la prescripción a pesar de alerta de alergia.

Módulo 10 — Laboratorio (Solicitudes y Resultados)

Gestiona el ciclo completo del análisis clínico: orden de solicitud → resultado con PDF externo. El hash SHA-256 del PDF de resultado es el mecanismo forense de verificación de integridad (Req 1 Cómputo Forense).

Tablas afectadas

solicitudes_estudio, resultados_laboratorio, auditoria_accesos, Azure Blob Storage

Reglas de negocio y seguridad

- Upload de resultados: el PDF del laboratorio externo se sube a Azure Blob Storage. El sistema calcula el SHA-256 del archivo y lo registra en auditoria_accesos.hash_archivo (Req 1 Forense).
- El PDF de resultado NO se modifica. Si el laboratorio emite una corrección, se crea un nuevo resultado con referencia a la solicitud original.
- SAS tokens de 15 minutos para descarga del PDF. Después del tiempo, el URL expira y requiere nueva solicitud.

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/encuentros/{id}/solicitudes	JWT (MED)	Genera orden de solicitud de estudio. Puede marcarse como urgente.
GET	/encuentros/{id}/solicitudes	JWT (MED, ENFERM)	Lista solicitudes del encuentro con estado (pendiente/con_resultado).
GET	/solicitudes/{id}/pdf	JWT (MED)	Descarga la solicitud de laboratorio como PDF generado por WeasyPrint.
POST	/solicitudes/{id}/resultados	JWT (MED, ENFERM)	Sube el PDF de resultado. El sistema calcula SHA-256 y sube a Azure Blob. Registra URL y hash.
GET	/solicitudes/{id}/resultados	JWT (MED)	Lista resultados de la solicitud con URL temporal (SAS 15 min) para descarga del PDF.

Módulo 11 — Referencias Médicas (SRC)

Implementa el Sistema de Referencia y Contrarreferencia (SRC) normado por la Secretaría de Salud. Una referencia con estado ACEPTADA o ATENDIDA es el mecanismo legal que habilita el acceso cross-establecimiento a notas clínicas (Regla 2 de Negocio).

Tablas afectadas

referencias_medicas, encuentros_clinicos, establecimientos, cat_especialidades_medicas, historial_cambios

Estados del ciclo de vida de una referencia

Estado	Significado y transiciones permitidas
EMITIDA	Estado inicial. El médico emisor crea la referencia. Transición: EMITIDA → ACEPTADA o CANCELADA.
ACEPTADA	El establecimiento destino acepta atender al paciente. HABILITA acceso a notas según Regla 2. Transición: ACEPTADA → ATENDIDA.
ATENDIDA	El paciente fue atendido en el establecimiento destino. Permite contrarreferencia. Estado mantiene el acceso a notas.
CANCELADA	La referencia fue cancelada antes de atención. REVOCA el acceso cross-establecimiento.

Tabla 11.1 — Ciclo de vida de una referencia médica

Endpoints

Método	Ruta	Auth requerida	Descripción
POST	/referencias	JWT (MED)	Emite una referencia médica. Requiere encuentro activo, establecimiento destino, especialidad y motivo clínico.
PATCH	/referencias/{id}/aceptar	JWT (MED, destino)	El médico del establecimiento receptor acepta la referencia. Habilita acceso cross-establecimiento (Regla 2).
PATCH	/referencias/{id}/atender	JWT (MED, destino)	Marca la referencia como atendida tras la consulta.
PATCH	/referencias/{id}/contrarreferir	JWT (MED, destino)	Envía resumen de contrarreferencia al establecimiento emisor.
PATCH	/referencias/{id}/cancelar	JWT (MED)	Cancela la referencia. Requiere justificación.
GET	/referencias/recibidas	JWT (MED)	Lista referencias recibidas en el establecimiento del médico autenticado.
GET	/referencias/emitidas	JWT (MED)	Lista referencias emitidas por el médico autenticado.
GET	/referencias/{id}/pdf	JWT (MED)	Genera el documento de referencia médica PDF conforme a NOM-004.

Módulo 12 — Generación de Documentos PDF

MedIA genera 4 documentos PDF a partir de datos ya registrados en la BD. Los documentos son generados on-demand por WeasyPrint y no se persisten en el sistema (excepción: resultados de laboratorio que llegan de fuente externa).

Principio de diseño (NOM-151 + Req 1 Forense)

- Los PDFs del expediente se generan desde datos ya validados y firmados. Autoría verificable, timestamp del servidor.
- El PDF de nota SOAP firmada incluye: sello visual con SHA-256 del contenido, cédula del médico, nombre del establecimiento con CLUES, timestamp CST exacto.
- El PDF de receta incluye: folio único, nombre genérico del medicamento, cédula del médico prescriptor, número de expediente.

Documento	Endpoint	Datos de origen
Nota SOAP firmada	GET /notas/{id}/pdf	notas_soap_detalle + notas_medicas + diagnosticos_encuentro + usuarios_sistema (cédula) + establecimientos (CLUES)
Receta médica nominativa	GET /encuentros/{id}/prescripciones/pdf	prescripciones + cat_medicamentos + usuarios_sistema + pacientes + personas
Solicitud de laboratorio	GET /solicitudes/{id}/pdf	solicitudes_estudio + encuentros_clinicos + pacientes + personas + usuarios_sistema
Referencia médica	GET /referencias/{id}/pdf	referencias_medicas + establecimientos (origen y destino) + pacientes + diagnosticos_encuentro

Tabla 12.1 — Documentos PDF generados por MedIA y sus fuentes de datos

Módulo 13 — Auditoría y Seguridad

Acceso a la bitácora inmutable y al panel de gestión de incidentes de seguridad. Solo el rol AUDITOR_SEGURIDAD tiene acceso a este módulo. El rol AUDITOR no puede ver datos clínicos de ningún paciente.

Tablas afectadas

auditoria_accesos (solo lectura), incidentes_seguridad (lectura/escritura), sesiones_invalidas, v_auditoria_estadistica

Requisitos de Cómputo Forense cubiertos por este módulo

- Req 1: auditoria_accesos incluye usuario, timestamp UTC, acción, resultado, IP (INET), hash de archivo, módulo y función (modulo_funcion).
- Req 3 Trazabilidad: el campo modulo_funcion permite responder '¿qué función firmó la nota?', '¿qué endpoint exportó resultados?'.
- Req 5 Acciones críticas: tipos de evento documentados: LOGIN_FALLIDO, CUENTA_BLOQUEADA, BORRADO_LOGICO, MODIFICACION_NO_AUTORIZADA, INTENTO_XSS, INTENTO_SQLI, INTENTO_IDOR, ACCESO_SIN_REFERENCIA.

Endpoints

Método	Ruta	Auth requerida	Descripción
GET	/auditoria/accesos	JWT (AUDIT)	Lista bitácora de accesos con filtros: tipo_evento, nivel_severidad, fecha_desde, fecha_hasta, id_usuario. Paginado. Solo lectura.
GET	/auditoria/estadisticas	JWT (AUDIT)	Consulta la vista v_auditoria_estadistica: eventos agrupados por tipo, módulo y fecha.
GET	/auditoria/incidentes	JWT (AUDIT)	Lista incidentes de seguridad con estado actual del ciclo de vida.
PATCH	/auditoria/incidentes/{id}	JWT (AUDIT)	Actualiza el estado del incidente (ABIERTO → EN_PROCESO → RESUELTO → CERRADO). Requiere descripcion_correccion para cierre.
GET	/auditoria/sesiones-invalidas	JWT (AUDIT)	Lista tokens JWT revocados activos (no expirados aún).

Módulo 14 — Configuración del Sistema (Admin)

Gestión de usuarios, roles, permisos y establecimientos. Solo accesible para ADMINISTRADOR y SUPERADMIN. Los cambios en permisos se registran en historial_cambios. El ADMINISTRADOR no tiene acceso a datos clínicos de pacientes.

Tablas afectadas

usuarios_sistema, roles, permisos_rol, usuarios_establecimientos, establecimientos, establecimientos_especialidades, cat_modulos, historial_cambios

Endpoints

Método	Ruta	Auth requerida	Descripción
GET	/admin/usuarios	JWT (ADMIN)	Lista usuarios del sistema con su rol y establecimientos asignados. Paginado con búsqueda.
POST	/admin/usuarios	JWT (ADMIN)	Crea nuevo usuario vinculado a una persona. Asigna rol y establecimiento inicial.
PATCH	/admin/usuarios/{id}	JWT (ADMIN)	Actualiza datos del usuario (username, cédula, rol). El cambio se registra en historial_cambios.
DELETE	/admin/usuarios/{id}	JWT (ADMIN)	Desactiva la cuenta (activo=false). Borrado lógico. El historial de auditoría se preserva.
GET	/admin/roles	JWT (ADMIN)	Lista roles disponibles con su matriz de permisos por módulo.
POST	/admin/roles/{id}/permisos	JWT (SUPERADMIN)	Actualiza la matriz CRUD del rol para un módulo específico. Registra cambio en historial_cambios.
GET	/admin/establecimientos	JWT (ADMIN)	Lista establecimientos del Distrito con sus especialidades activas.
POST	/admin/establecimientos/{id}/especialidades	JWT (ADMIN)	Habilita una especialidad en un establecimiento.
DELETE	/admin/establecimientos/{id}/especialidades/{id_esp}	JWT (ADMIN)	Desactiva una especialidad. Requiere motivo_desactivacion. Registra en historial_cambios.

Módulo 15 — Catálogos

Endpoints de consulta de catálogos estáticos y clínicos. Los catálogos de solo lectura están replicados en CDN para latencia mínima. Los catálogos geográficos INEGI son la base del domicilio estructurado.

Tablas afectadas

cat_cie10, cat_medicamentos, cat_especialidades_medicas, cat_lenguas_indigenas, cat_modulos, cat_estados, cat_municipios, cat_localidades, jurisdicciones_sanitarias

Estrategia de caché (Cómputo Distribuido)

- cat_cie10 y cat_medicamentos: cacheados en Azure CDN. TTL de 24 horas. Invalidados manualmente desde POST /admin/cache/invalidate.
- cat_estados, cat_municipios, cat_localidades: cacheados en CDN con TTL de 7 días. Solo cambian cuando el INEGI publica nueva versión del catálogo.
- Catálogos de acceso clínico (cat_especialidades_medicas): NO se cachean. Requieren datos en tiempo real para validación de acceso cross-establecimiento.

Endpoints

Método	Ruta	Auth requerida	Descripción
GET	/catalogos/cie10?q={texto}	JWT	Búsqueda de diagnósticos CIE-10 por código o descripción (ILIKE). Máximo 20 resultados. Para autocompletado en frontend.
GET	/catalogos/medicamentos?q={nombre}	JWT	Búsqueda en Cuadro Básico SSA por nombre genérico. Máximo 20 resultados.
GET	/catalogos/especialidades	JWT	Lista de especialidades médicas. Usada en formulario de referencia.
GET	/catalogos/lenguas	JWT	Catálogo INALI de lenguas indígenas de Chiapas.
GET	/catalogos/jurisdicciones	JWT	Jurisdicciones sanitarias del estado con municipio sede.
GET	/catalogos/modulos	JWT (ADMIN)	Lista módulos del sistema para configuración de permisos de rol.
POST	/admin/cache/invalidate	JWT (SUPERADMIN)	Fuerza invalidación del cache CDN de catálogos. Para cuando se actualiza CIE-10 o medicamentos.

Resumen de Vistas SQL

Las siguientes vistas SQL se definen en database/02_triggers.sql y son consultadas directamente desde los services del backend:

Vista	Acceso	Propósito
v_paciente_basico	Roles admin	Datos básicos del paciente sin CURP ni datos clínicos. Para listados administrativos sin exposición de datos sensibles.

v_auditoria_estadistica	AUDITOR	Eventos agrupados por tipo, módulo y fecha sin identificación de usuarios. Para dashboard estadístico del auditor.
v_signos_encuentro	Enfermería	signos_vitales JOIN encuentros_clinicos. Permite que Enfermería consulte signos sin acceso a notas SOAP.

Tabla 15.1 — Vistas SQL de seguridad por nivel de acceso